Manual Técnico y Especificación de Requerimientos del Sistema: Herb Hopper

Tienda virtual Android para la dispensación de cannabis medicinal

David Santiago Lugo Corredor

Fundación Universitaria Compensar

Desarrollo de Aplicaciones Móviles Nativas

Docente: Angie Paola Rique Sabogal

28 de septiembre de 2026

Tabla de Contenido

Introducción 3
Enfoque del Proyecto 3
¿De qué trata? 3
Enfoque temático y comercial 3
¿Por qué se eligió este nicho? 4
Normatividad Legal 4
Arquitectura Modular del Aplicativo 6
Requerimientos 7
Requerimientos Funcionales 7
Requerimientos No Funcionales 15
Modelo de Datos 16
Flujo del Proceso de Compra y Pago 17
Mockup 18
Comprador (Paciente) 18
Vendedor (Dispensario) 23
Administrador 26
Referencias 29

Introducción

Este documento aborda la planeación técnica de Herb Hopper, una tienda virtual nativa para Android orientada a la venta de productos derivados del cannabis medicinal en Colombia. Reúne en un solo lugar el enfoque comercial del proyecto, el marco legal que condiciona su desarrollo, la especificación de requerimientos funcionales y no funcionales, la arquitectura modular del aplicativo y los mockups de sus tres roles: comprador (paciente), vendedor (dispensario) y administrador.

Su finalidad es servir como base lógica para la construcción y verificación del software. Cada requerimiento se describe con su prioridad y con observaciones concretas para el desarrollador sobre los datos, los metadatos y los controles de seguridad que debe implementar. Además, el documento corresponde a la versión del código fuente publicada en el repositorio del proyecto, de modo que sirve para comprobar que lo especificado y lo construido coinciden.

Enfoque del Proyecto

¿De qué trata?

Herb Hopper es una plataforma de comercio electrónico B2C (*Business to Consumer*) que conecta dispensarios autorizados con pacientes que requieren productos de cannabis medicinal. El paciente consulta un catálogo con la ficha técnica de cada producto, carga su fórmula médica con la cámara del teléfono, paga en línea con tarjeta, PSE o efectivo a través de ePayco y sigue el estado de su pedido. El vendedor administra el inventario, verifica las fórmulas y despacha los pedidos. El administrador gobierna usuarios, sucursales e infraestructura.

Enfoque temático y comercial

El enfoque es la dispensación responsable: el catálogo se organiza en siete categorías (líquidos y aceites, comestibles, tópicos, bienestar y cuidado, concentrados y otros, bebidas y suplementos, y comestibles especializados) y cada producto declara su concentración, su porcentaje de THC, sus beneficios, su modo de uso y sus certificaciones. Los productos con 1 % de THC o más se consideran de control especial y solo se venden con una fórmula médica aprobada por un farmacéutico. El modelo de ingresos es la venta directa con pago electrónico y entrega a domicilio en la dirección que el paciente registra con geolocalización.

¿Por qué se eligió este nicho?

Se eligió por tres razones de mercado. Primero, desde la Ley 1787 de 2016 y su reglamentación en el Decreto 811 de 2021, Colombia cuenta con un marco legal para el uso médico del cannabis, lo que ha permitido la aparición de laboratorios y dispensarios licenciados que necesitan canales de venta formales. Segundo, los pacientes con tratamientos prolongados (dolor crónico, ansiedad, insomnio, afecciones dermatológicas) requieren compras recurrentes y valoran recibir los productos en casa sin desplazarse. Tercero, buena parte de la oferta actual circula por canales informales sin trazabilidad ni control de fórmulas; una tienda virtual que exige la fórmula médica, registra cada transacción y muestra la ficha técnica de cada producto ofrece al paciente una alternativa segura y al dispensario una forma de cumplir la norma. Desde lo tecnológico, el nicho exige precisamente las capacidades nativas que se estudian en el curso: cámara para digitalizar fórmulas, geolocalización para la entrega, autenticación biométrica para proteger datos de salud y APIs externas para pagos y almacenamiento.

Normatividad Legal

La Tabla 1 identifica las leyes y regulaciones colombianas que aplican al desarrollo y la operación de la tienda virtual, y explica cómo cada una se traduce en decisiones concretas del software.

Tabla 1

Normatividad aplicable y su influencia en el desarrollo

Ley / Norma	**Descripción**	**Influencia y Aplicación en el Desarrollo**
Ley 527 de 1999	Define y reglamenta el acceso y uso de los mensajes de datos, del comercio electrónico y de las firmas digitales. Otorga validez jurídica a los contratos celebrados por medios electrónicos.	Es la base legal de la tienda virtual: el pedido confirmado en la app es un mensaje de datos con validez contractual. Por eso cada pedido se guarda en el servidor con identificador único, fecha, productos, precio y estado, y cada cambio de estado queda en la bitácora de auditoría (integridad y conservación del mensaje de datos).
Ley 1480 de 2011 (Estatuto del Consumidor)	Protege los derechos de los consumidores. Para el comercio electrónico exige información veraz, precio total con impuestos, derecho de retracto y reversión del pago.	El checkout muestra el precio final en COP con impuestos incluidos antes de pagar y el servidor recalcula el total con los precios de la base de datos. El paciente puede cancelar su pedido mientras no esté pagado ni aceptado, y las cancelaciones y pagos rechazados devuelven el stock de forma automática.
Decreto 587 de 2016 (compilado en el Decreto 1074 de 2015)	Reglamenta la reversión del pago en ventas no presenciales con tarjeta de crédito, débito o instrumentos electrónicos.	El estado del pago lo informa la pasarela (ePayco) al backend y queda asociado a la referencia del pedido. Esa referencia se muestra al usuario en la confirmación de pago y en el rastreo del pedido, para que pueda solicitar la reversión.
Ley 1581 de 2012 (Protección de Datos Personales)	Régimen general de protección de datos. Exige autorización previa del titular, protección reforzada de datos sensibles (como los de salud) y garantiza los derechos de conocer, actualizar, rectificar y suprimir.	El registro exige aceptar la autorización de tratamiento de datos. Las fórmulas médicas son datos sensibles: se guardan en almacenamiento privado y solo se entregan al farmacéutico mediante enlaces firmados que vencen en 10 minutos. El usuario puede editar su perfil y eliminar su cuenta. La bitácora no registra contraseñas, tarjetas ni el contenido de las fórmulas.
Decreto 1377 de 2013	Reglamenta parcialmente la Ley 1581: forma de obtener la autorización, políticas de	La autorización se obtiene con una casilla explícita en el registro. Los tokens de sesión son de vida corta (1 hora) y los de renovación se pueden revocar desde el

	tratamiento y transferencia de datos.	servidor (cierre de sesión, cambio de contraseña o inactivación de la cuenta).
Ley 1787 de 2016	Crea el marco regulatorio que permite el acceso seguro e informado al uso médico y científico del cannabis y sus derivados.	Solo se venden productos de dispensarios registrados por el administrador (gobernanza de sucursales con número de licencia y estado verificado). La compra de productos de control especial exige una fórmula médica.
Decreto 811 de 2021	Reglamenta la Ley 1787. Distingue los derivados psicoactivos (1 % de THC o más en peso seco) de los no psicoactivos y regula su control.	Cada producto registra su porcentaje de THC; con 1 % o más el servidor lo marca como de fórmula obligatoria. El pedido no se crea sin una fórmula del paciente que no esté rechazada, y el vendedor no puede aceptarlo hasta aprobar la fórmula.
Ley 1273 de 2009 (Delitos Informáticos)	Tipifica delitos como el acceso abusivo a sistemas informáticos, la violación de datos personales y la suplantación de sitios.	El backend exige autenticación con JWT y control de acceso por rol en cada ruta protegida, limita los intentos de inicio de sesión y registra los accesos fallidos para su auditoría.
Estándar PCI DSS (norma de la industria de tarjetas)	Requisitos de seguridad para quienes procesan, almacenan o transmiten datos de tarjetas.	La app nunca pide ni guarda datos de tarjeta: el pago se hace en el checkout oficial de ePayco. La llave privada de ePayco solo vive en el servidor y la confirmación de pago se valida con su firma SHA-256.

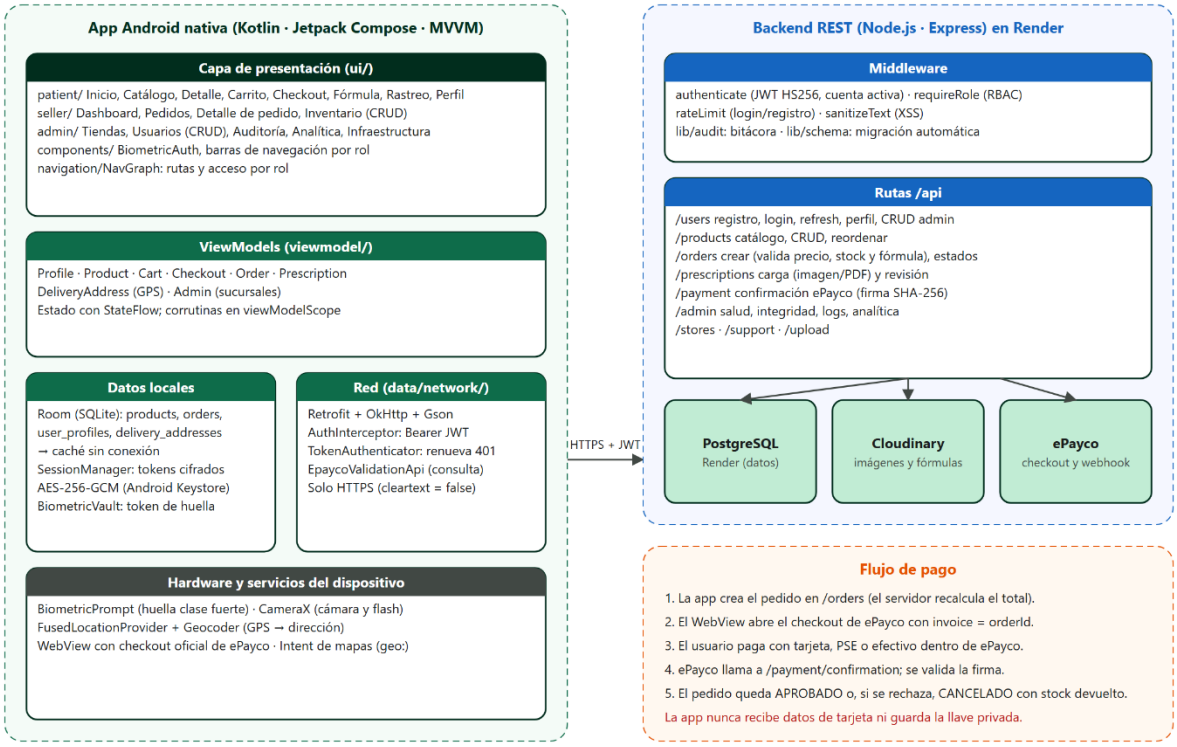
Nota. Elaboración propia a partir de la normativa citada en las referencias.

Arquitectura Modular del Aplicativo

El sistema tiene dos componentes: la app nativa Android y un backend REST. La app está escrita en Kotlin con Jetpack Compose y sigue el patrón MVVM: las pantallas (capa de presentación) observan el estado de los ViewModels, y estos obtienen los datos del backend mediante Retrofit y los guardan en Room (SQLite) para usarlos sin conexión. El backend está escrito en Node.js con Express, usa PostgreSQL como base de datos y se despliega en Render. La Figura 1 muestra los módulos y sus dependencias.

Figura 1

Arquitectura modular de Herb Hopper



Nota. Elaboración propia.

Los módulos funcionales son: Inicio, Autenticación, Administración de Usuarios, Perfil, Productos (catálogo e inventario), Carrito, Pedidos (compras), Pasarela de Pagos, Fórmulas Médicas, Geolocalización, Soporte y Administración del Sistema. Las APIs externas son ePayco (pagos), Cloudinary (almacenamiento de imágenes y fórmulas) y el backend propio de autenticación con JWT. El Android Keystore protege las claves de cifrado del dispositivo.

Requerimientos

Los requerimientos se dividen en funcionales (qué hace el sistema) y no funcionales (con qué calidad lo hace). La prioridad se clasifica como Alta (imprescindible para operar), Media (necesaria para la experiencia completa) o Baja (mejora deseable).

Requerimientos Funcionales

Las tablas 2 a 13 presentan los requerimientos funcionales agrupados por módulo.

Tabla 2

Módulo Inicio

No.	Descripción Técnica	Prioridad	Observaciones para el Desarrollador (datos, metadatos y seguridad)
RF-01	Pantalla de inicio (splash) que verifica si existe una sesión guardada y dirige al usuario al inicio de su rol (catálogo, dashboard del vendedor o control de tiendas) o a la pantalla de acceso.	Alta	Datos: rol y token cifrado en SessionManager. Seguridad: el token de acceso se descifra con la clave del Keystore; si falta o no se puede descifrar, se exige un nuevo inicio de sesión.
RF-02	Catálogo como pantalla de inicio del comprador: productos en cuadrícula con imagen, nombre y precio, filtro por las siete categorías y búsqueda por nombre o descripción.	Alta	Datos: GET /api/products (público). Metadatos: categoría, precio en COP. El filtrado se hace en el ViewModel con StateFlow. Room guarda la última copia para mostrarla sin conexión.

Tabla 3

Módulo Autenticación

No.	Descripción Técnica	Prioridad	Observaciones para el Desarrollador (datos, metadatos y seguridad)
RF-03	Registro de cuenta como Paciente o Vendedor con nombre, correo, celular, contraseña y autorización de tratamiento de datos.	Alta	Validación en app y servidor: correo de Gmail, Outlook, Hotmail, Yahoo o iCloud (dominio exacto); celular colombiano de 10 dígitos que empieza por 3; contraseña de 8 o más caracteres con mayúscula, minúscula, número y carácter especial. La contraseña se guarda con hash bcrypt. El rol ADMIN no se puede elegir en el registro.
RF-04	Inicio de sesión con correo y contraseña contra POST /api/users/login.	Alta	Respuesta: JWT de acceso (1 h) y token de renovación (30 días, guardado como hash SHA-256 en la base de datos). Los tokens se guardan cifrados con AES-256-GCM (Android Keystore). Límite de 20 intentos cada 15 minutos por IP; los intentos fallidos van a la bitácora. Mensaje genérico ante credenciales erradas.

RF-05	Acceso con huella dactilar mediante BiometricPrompt. Tras el primer ingreso, la app pregunta si se desea activar; si el usuario acepta, se guarda un token de dispositivo exclusivo.	Alta	El token de dispositivo se cifra con una clave del Keystore que exige autenticación biométrica fuerte y se invalida si se registra una huella nueva. Nunca se guarda la contraseña. Cada uso rota el token (POST /api/users/refresh con device = true).
RF-06	Renovación automática de la sesión y cierre de sesión.	Alta	Ante un 401, el TokenAuthenticator de OkHttp renueva el JWT una vez. El cierre de sesión revoca el token en el servidor y borra la caché local de pedidos.
RF-07	Solicitud de restablecimiento de contraseña.	Media	POST /api/users/forgot-password registra la solicitud; el administrador la atiende desde el módulo de usuarios.

Tabla 4

Módulo Administración de Usuarios (CRUD de Usuario)

No.	**Descripción Técnica**	**Prioridad**	**Observaciones para el Desarrollador (datos, metadatos y seguridad)**
RF-08	Crear usuarios con rol PATIENT, SELLER o ADMIN.	Alta	POST /api/users/admin-create, solo con token de rol ADMIN. Aplica la misma política de contraseña.
RF-09	Consultar usuarios agrupados en compradores, vendedores y administradores.	Alta	GET /api/users (ADMIN). Nunca devuelve el hash de la contraseña.
RF-10	Actualizar nombre, correo, rol y, opcionalmente, contraseña de un usuario.	Alta	PUT /api/users/:id (ADMIN). Si cambia la contraseña, se revocan los tokens de ese usuario. Cada cambio queda en la bitácora.
RF-11	Inactivar o reactivar cuentas (por violaciones de seguridad o soportes médicos falsos).	Alta	PATCH /api/users/:id/status. Una cuenta inactiva no puede iniciar sesión y sus tokens se revocan. El administrador no puede inactivarse a sí mismo.
RF-12	Eliminar usuarios.	Media	DELETE /api/users/:id (ADMIN). Borrado en cascada de tokens, fórmulas, pedidos y mensajes del usuario.

Tabla 5

Módulo Perfil (CRUD de Perfil)

No.	Descripción Técnica	Prioridad	Observaciones para el Desarrollador (datos, metadatos y seguridad)
RF-13	Consultar el perfil propio.	Alta	GET /api/users/me con JWT. Se guarda una copia en Room (user_profiles).
RF-14	Editar nombre y celular, y cambiar la contraseña.	Alta	PUT /api/users/me. El correo solo lo cambia un administrador. El cambio de contraseña revoca las sesiones guardadas, incluida la de la huella.
RF-15	Gestionar direcciones de entrega (crear, editar, eliminar y marcar una como predeterminada).	Alta	Tabla Room delivery_addresses con etiqueta, dirección, latitud y longitud. Ver el módulo de geolocalización.
RF-16	Eliminar la propia cuenta (derecho de supresión).	Media	DELETE /api/users/me; la app borra además la base de datos local y la bóveda biométrica.

Tabla 6

Módulo Productos (Catálogo y CRUD de Productos)

No.	Descripción Técnica	Prioridad	Observaciones para el Desarrollador (datos, metadatos y seguridad)
RF-17	Detalle del producto con concentración, porcentaje de THC, beneficios clínicos, modo de uso, certificaciones, stock disponible y aviso de fórmula obligatoria.	Alta	Campos de la tabla products: cbdConcentration, thcPercent, benefits, usageMode, certifications, stock, requiresPrescription. El botón de agregar se desactiva si no hay stock.
RF-18	Crear productos con imagen, nombre, precio, categoría, descripción, stock, stock mínimo y ficha técnica.	Alta	POST /api/products (SELLER o ADMIN). Validación: precio mayor a cero, THC entre 0 y 100, stock no negativo. Los textos se limpian de etiquetas HTML. Imagen: POST /api/upload a Cloudinary (máximo 5 MB, solo imágenes).
RF-19	Consultar el inventario con indicador CRÍTICO cuando el stock es menor o igual al mínimo.	Alta	Cálculo stock ≤ minStock en el modelo Product. El dashboard lista los productos críticos.

RF-20	Actualizar y eliminar productos.	Alta	PUT y DELETE /api/products/:id. Los cambios se registran en la bitácora. La app solo actualiza su copia local si el servidor confirma.
RF-21	Botón "Reordenar" que solicita reabastecimiento al administrador.	Media	POST /api/products/:id/reorder crea un registro en restock_requests. El administrador lo atiende desde Infraestructura y el stock se suma automáticamente.

Tabla 7

Módulo Carrito (CRUD de Carrito)

No.	**Descripción Técnica**	**Prioridad**	**Observaciones para el Desarrollador (datos, metadatos y seguridad)**
RF-22	Agregar productos al carrito desde el catálogo o el detalle.	Alta	CartViewModel con StateFlow<List<CartItem>>. Si el producto ya está, aumenta la cantidad.
RF-23	Consultar el carrito con subtotal por ítem y total.	Alta	El total mostrado es informativo: el servidor lo recalcula al crear el pedido.
RF-24	Modificar cantidades y eliminar ítems.	Alta	La cantidad mínima es 1. El stock se valida en el servidor al confirmar el pedido.
RF-25	Vaciar el carrito al completar un pago aprobado o pendiente, o al cerrar sesión.	Media	clearCart() en la navegación tras la confirmación de ePayco.

Tabla 8

Módulo Pedidos (CRUD de Compras)

No.	**Descripción Técnica**	**Prioridad**	**Observaciones para el Desarrollador (datos, metadatos y seguridad)**
RF-26	Crear el pedido con productos, dirección con coordenadas, fórmula (si aplica) y método de pago.	Alta	POST /api/orders (PATIENT). En una transacción: bloquea las filas de producto, valida stock, recalcula el total, exige fórmula no rechazada si algún producto la requiere y descuenta el stock. El orderId es también la factura en ePayco.

RF-27	Consultar pedidos: el paciente ve solo los suyos; el vendedor y el administrador ven todos.	Alta	GET /api/orders filtra por el rol del JWT. Incluye el estado de pago y el de la fórmula.
RF-28	Rastreo del pedido con línea de tiempo (recibido, aceptado, entregado o cancelado), estado del pago, estado de la fórmula y dirección de entrega con enlace al mapa.	Alta	GET /api/orders/:id (dueño o personal). El mapa se abre con un Intent geo: usando latitud y longitud.
RF-29	El vendedor cambia el estado: ACEPTAR, CANCELAR o MARCAR COMO ENTREGADO.	Alta	PUT /api/orders/:id/status (SELLER o ADMIN). Reglas: aceptar exige fórmula aprobada; entregar exige pedido aceptado; cancelar devuelve el stock; un pedido cerrado no cambia.
RF-30	El paciente cancela su pedido mientras no esté pagado ni aceptado (retracto).	Media	PUT /api/orders/:id/cancel. También se usa si el paciente abandona el checkout de ePayco.
RF-31	Dashboard del vendedor con ventas del día en COP y número de pedidos nuevos.	Alta	GET /api/orders/stats/today: suma solo pagos aprobados del día; los pedidos nuevos son los PENDING. La burbuja se resalta en rojo si hay pedidos por verificar.

Tabla 9

Módulo Pasarela de Pagos

No.	**Descripción Técnica**	**Prioridad**	**Observaciones para el Desarrollador (datos, metadatos y seguridad)**
RF-32	Pago con tarjeta de crédito o débito, PSE o efectivo mediante el checkout oficial de ePayco en un WebView. Solo se muestra el medio elegido.	Alta	La app envía la llave pública, el monto calculado por el servidor, la factura (orderId) y los datos del comprador. Los datos de la tarjeta se digitan en ePayco; la app no los ve (PCI DSS).

RF-33	Confirmación servidor a servidor del resultado del pago.	Alta	POST o GET /api/payment/confirmation. Valida x_signature = SHA-256(p_cust_id_cliente^p_key^x_ref_payco^x_transaction_id^x_amount^x_currency_code) y que el monto coincida. Actualiza paymentStatus y paymentRef; si el pago se rechaza, cancela el pedido y devuelve el stock.
RF-34	Pantalla de confirmación con el estado (aprobado, pendiente, rechazado) y la referencia de ePayco.	Alta	La app consulta la referencia en el servicio público de validación de ePayco solo para mostrarla; la fuente de verdad es la confirmación del servidor.

Tabla 10

Módulo Fórmulas Médicas (cámara y almacenamiento)

No.	Descripción Técnica	Prioridad	Observaciones para el Desarrollador (datos, metadatos y seguridad)
RF-35	Captura de la fórmula con la cámara (CameraX) con control de flash, o selección de una imagen o un PDF.	Alta	Permiso CAMERA en tiempo de ejecución. La foto se guarda como JPEG en la caché privada de la app antes de enviarla.
RF-36	Envío de la fórmula con el nombre y el registro médico del profesional.	Alta	POST /api/prescriptions (multipart, máximo 10 MB, JPG, PNG, WEBP o PDF). Se guarda en Cloudinary como recurso autenticado (privado). Estado inicial PENDING; plazo de revisión de 24 h.
RF-37	Revisión por el farmacéutico: ver la fórmula, verificar registro, sello y firma, y aprobar o rechazar con motivo.	Alta	PUT /api/prescriptions/:id/review (SELLER o ADMIN). La fórmula se abre con una URL firmada que vence en 10 minutos. Queda registro de quién revisó y cuándo.
RF-38	"Mis fórmulas": el paciente consulta el estado de sus fórmulas y el motivo de un rechazo.	Media	GET /api/prescriptions filtra por usuario.

Tabla 11

Módulo Geolocalización

No.	Descripción Técnica	Prioridad	Observaciones para el Desarrollador (datos, metadatos y seguridad)
RF-39	Obtener la ubicación actual y convertirla en una dirección para registrar direcciones de entrega.	Alta	FusedLocationProviderClient (alta precisión, una lectura) y Geocoder con configuración regional es-CO. Permiso ACCESS_FINE_LOCATION.
RF-40	Enviar las coordenadas con el pedido y mostrarlas al vendedor y al paciente con enlace al mapa.	Alta	Columnas latitude y longitude en orders.

Tabla 12

Módulo Soporte

No.	Descripción Técnica	Prioridad	Observaciones para el Desarrollador (datos, metadatos y seguridad)
RF-41	Centro de ayuda con preguntas frecuentes y envío de correo a soporte.	Media	Intent mailto: a soporte@herbhopper.com.
RF-42	Chat de soporte: el usuario escribe y el equipo responde desde la mesa de ayuda del administrador.	Media	Tabla support_messages; /api/support/messages para el usuario y /api/support/conversations para el administrador. La app actualiza la conversación cada 10 segundos.

Tabla 13

Módulo Administración del Sistema

No.	Descripción Técnica	Prioridad	Observaciones para el Desarrollador (datos, metadatos y seguridad)
RF-43	Gobernanza de sucursales: registrar, verificar, suspender y eliminar dispensarios.	Alta	/api/stores (ADMIN escribe; SELLER consulta). Datos centralizados: todos los dispositivos ven la misma lista.

RF-44	Panel de infraestructura: estado y latencia de la base de datos, porcentaje de integridad y botón "Reiniciar Servicios".	Alta	GET /api/admin/health ejecuta ocho verificaciones de consistencia (por ejemplo, stock negativo, pedidos aceptados con fórmula no aprobada, contraseñas sin cifrar). "Reiniciar" recicla el pool de conexiones de la API.
RF-45	Bitácora de auditoría filtrable por accesos, tokens, ePayco, pedidos, fórmulas, inventario, administración e infraestructura.	Alta	GET /api/admin/logs. Los eventos de advertencia se resaltan. No se registran datos sensibles.
RF-46	Analítica global: ventas aprobadas, usuarios activos, pedidos y distribución por estado, medio de pago y rol.	Media	GET /api/admin/analytics.

Requerimientos No Funcionales

Tabla 14

Requerimientos no funcionales

No.	Descripción Técnica	Prioridad	Observaciones para el Desarrollador (datos, metadatos y seguridad)
RNF-01	**Seguridad en tránsito.** Toda comunicación usa HTTPS (TLS).	Alta	usesCleartextTraffic = false en el manifiesto; el backend redirige HTTP a HTTPS en producción. El registro de red solo existe en compilaciones de depuración, solo con encabezados y ocultando Authorization.
RNF-02	**Seguridad en reposo.** Tokens cifrados con AES-256-GCM y claves en el Android Keystore; contraseñas con bcrypt; tokens de renovación guardados como hash SHA-256.	Alta	Copias de seguridad de Android desactivadas (allowBackup = false) para no extraer datos de salud. Los secretos del servidor (base de datos, JWT, Cloudinary, ePayco) se leen de variables de entorno, nunca del código.
RNF-03	**Control de acceso.** Autenticación con JWT y autorización por rol (RBAC) en cada ruta.	Alta	Middleware authenticate (valida firma, vencimiento y cuenta activa) y requireRole. Sin credenciales fijas ni accesos ocultos en la app.
RNF-04	**Protección contra ataques comunes.** Fuerza bruta, inyección SQL, XSS y manipulación de precios.	Alta	Límite de intentos en login y registro; consultas parametrizadas ($1, $2…); limpieza

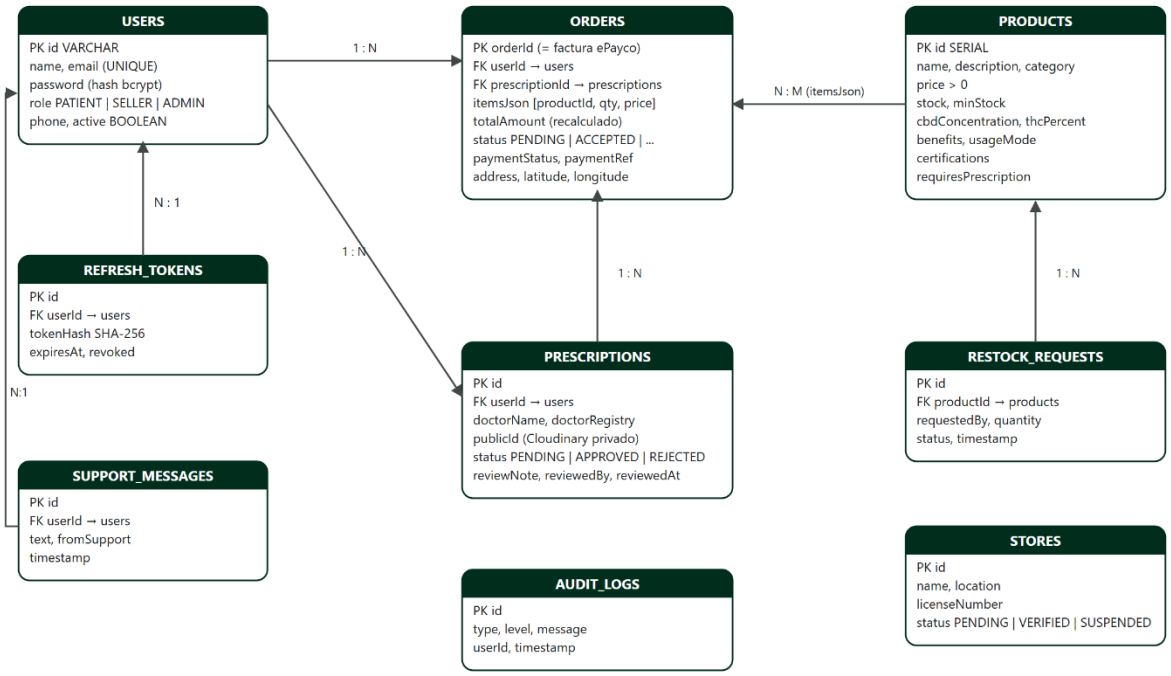
			de etiquetas HTML; precios y totales calculados en el servidor.
RNF-05	**Rendimiento.** Las consultas de catálogo y pedidos deben responder en menos de 500 ms con el servicio activo.	Media	Tiempos de espera de 30 s (conexión) y 60 s (lectura) en la app para tolerar el arranque en frío del plan gratuito de Render. Filtrado del catálogo en memoria con StateFlow.
RNF-06	**Disponibilidad y tolerancia a fallos.** La app debe seguir mostrando catálogo y pedidos sin conexión.	Media	Caché en Room. El esquema de la base de datos se crea o actualiza de forma idempotente al iniciar el servidor. Las operaciones de pedido y pago usan transacciones.
RNF-07	**Usabilidad.** Interfaz con Material Design 3, navegación inferior por rol, mensajes de error en español claros y ayuda de requisitos en los formularios.	Alta	Textos en strings.xml. Paleta institucional: verde bosque #012D1D, verde secundario #0E6C4A y menta #C1ECD4.
RNF-08	**Compatibilidad.** Android 9.0 (API 28) o superior.	Alta	minSdk 28, targetSdk y compileSdk 34. Huella de clase fuerte (BIOMETRIC_STRONG).
RNF-09	**Escalabilidad.** El backend es sin estado (JWT) y se empaqueta en contenedor.	Media	Dockerfile con Node 20. Se pueden agregar instancias en Render sin cambios de código; el único estado en memoria es el limitador de intentos.
RNF-10	**Mantenibilidad y trazabilidad.** Código modular (MVVM y rutas por dominio) y bitácora de auditoría.	Media	Pruebas de las reglas de validación con npm test. Cada acción sensible queda registrada con tipo, nivel, usuario y fecha.

Modelo de Datos

La Figura 2 muestra el modelo entidad-relación de la base de datos central en PostgreSQL. Los productos de cada pedido se guardan en el campo itemsJson con el precio aplicado en el momento de la compra, lo que conserva el valor histórico aunque el precio cambie después.

Figura 2

Modelo entidad-relación



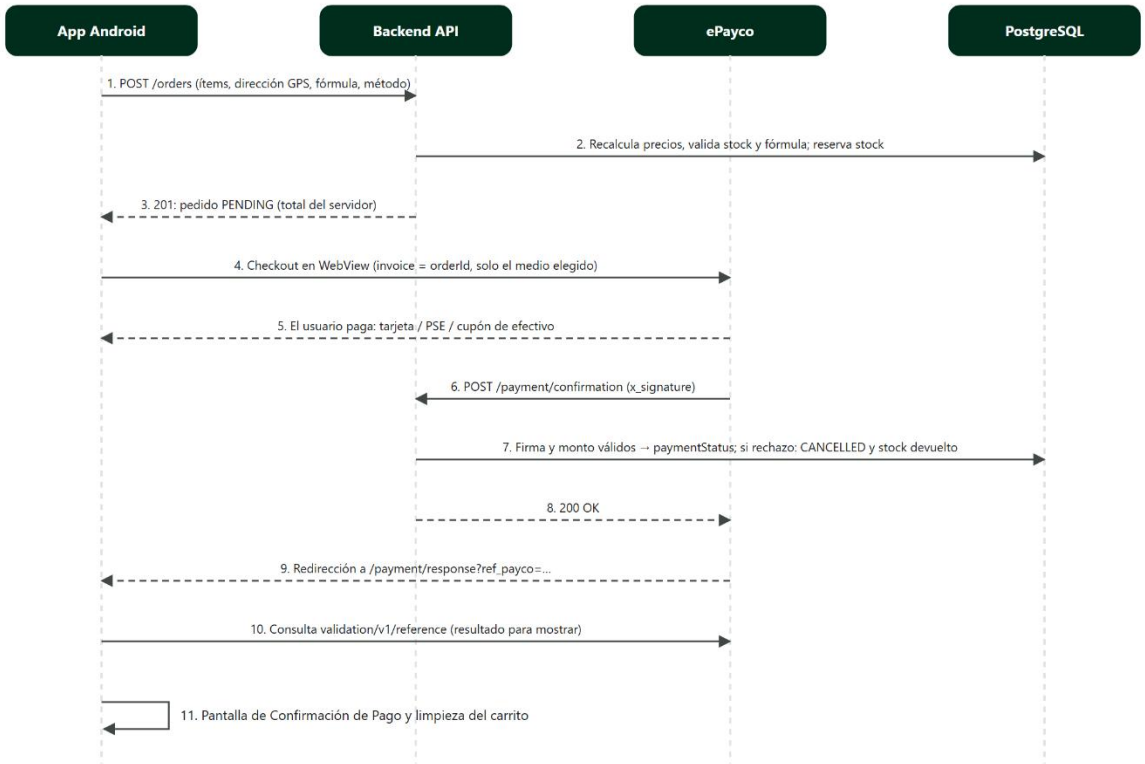
Nota. Elaboración propia.

Flujo del Proceso de Compra y Pago

La Figura 3 describe la secuencia completa desde que el comprador confirma el pedido hasta que ve el resultado del pago.

Figura 3

Diagrama de secuencia del pago



Nota. Elaboración propia.

Mockup

Los mockups representan la interfaz de cada rol con los colores, la estructura y la distribución de componentes de la implementación: fondo claro #F8F9FA, títulos y botones principales en verde bosque #012D1D, acciones secundarias en #0E6C4A, tarjetas con esquinas redondeadas y barra de navegación inferior propia de cada rol. Cada rol tiene primero su diagrama de navegación y luego sus pantallas principales.

Comprador (Paciente)

Figura 4

Flujo de navegación del comprador

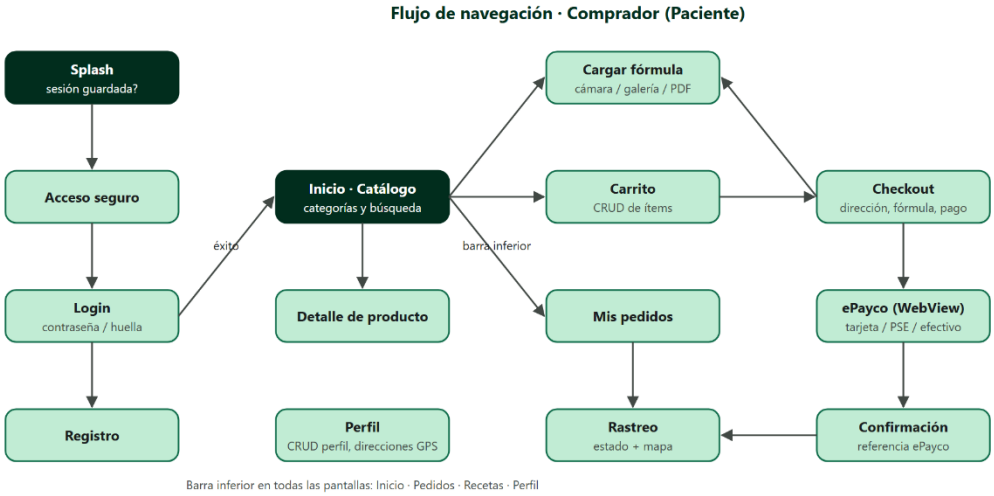
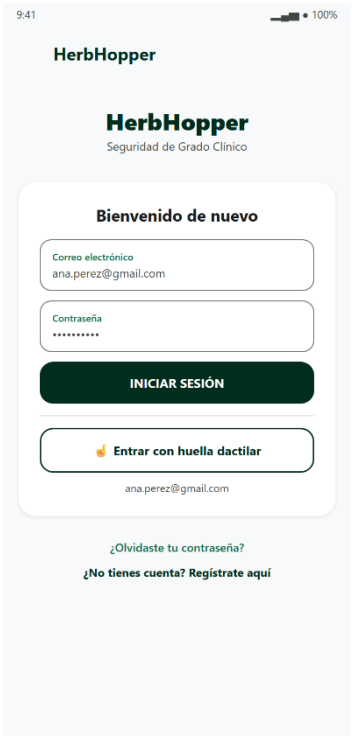


Figura 5

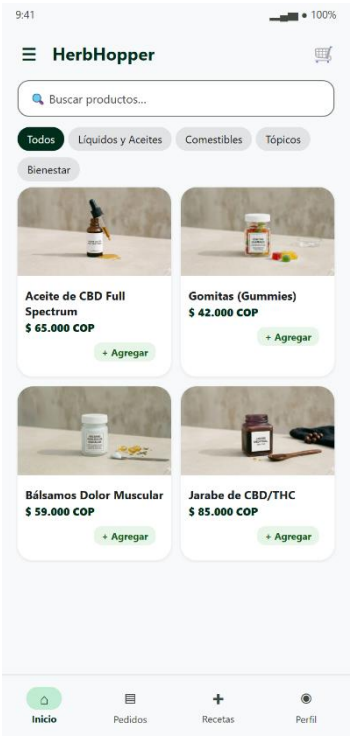
Pantallas del comprador: acceso, registro, catálogo y detalle



Inicio de sesión con huella



Registro



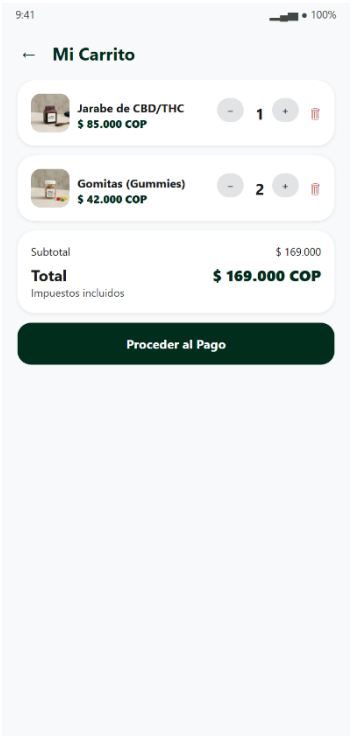
Inicio · Catálogo

Figura 6

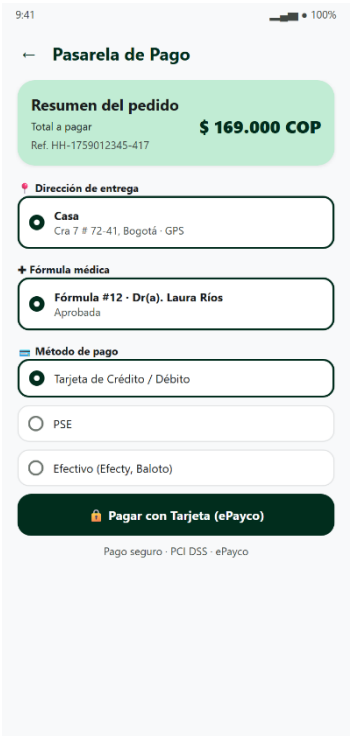
Pantallas del comprador: detalle, carrito y pasarela de pagos



Detalle de producto



Carrito (CRUD)



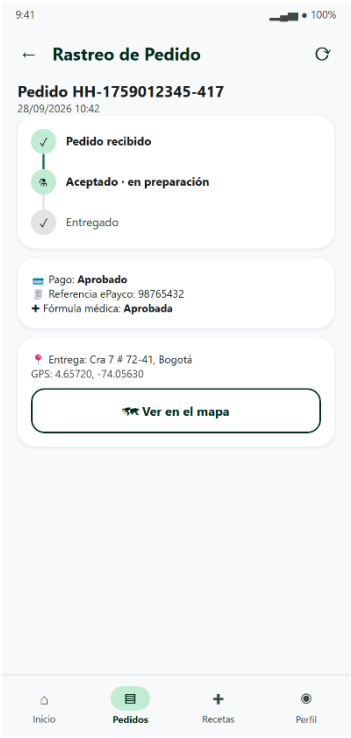
Pasarela de pagos

Figura 7

Pantallas del comprador: carga de fórmula y rastreo



Cargar fórmula (cámara)



Rastreo del pedido

Vendedor (Dispensario)

Figura 8

Flujo de navegación del vendedor

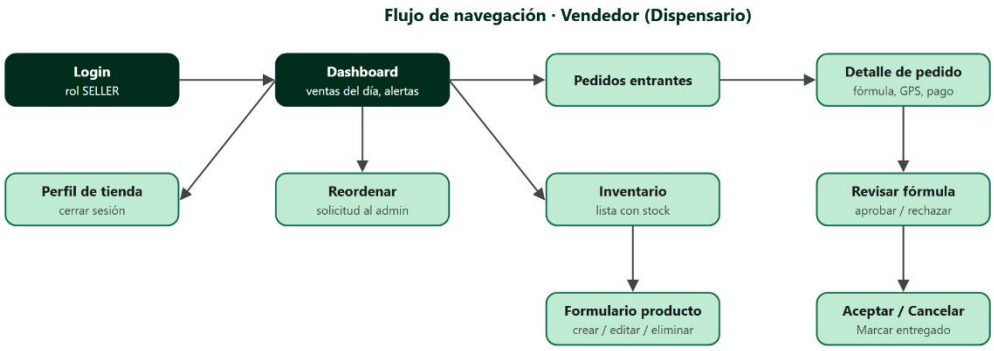
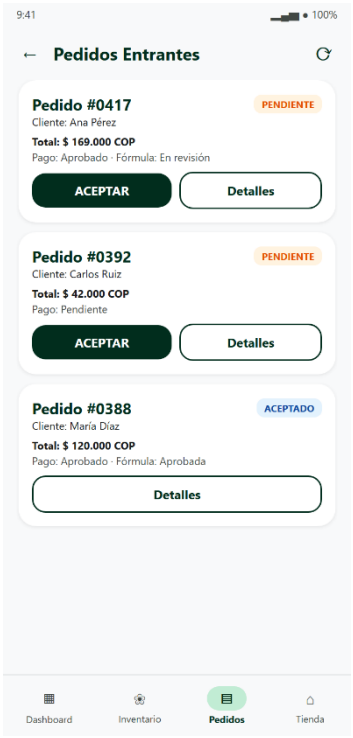


Figura 9

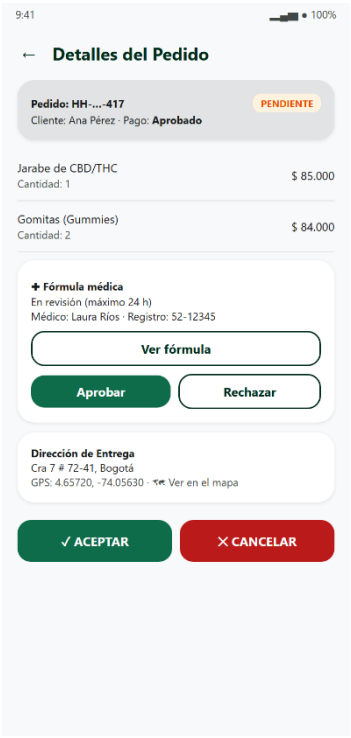
Pantallas del vendedor: dashboard, pedidos y detalle de pedido



Dashboard



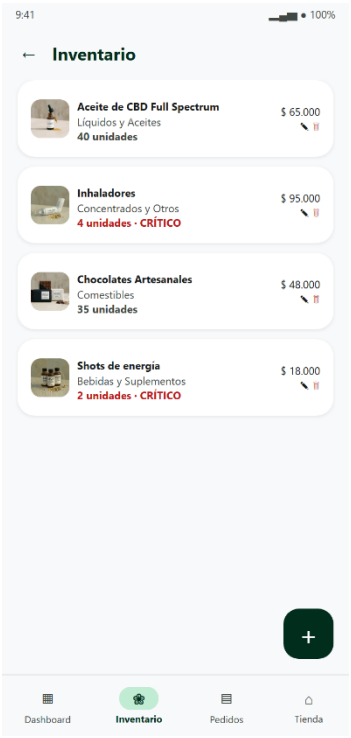
Pedidos entrantes



Detalle y revisión de fórmula

Figura 10

Pantallas del vendedor: inventario y CRUD de productos



Inventario



Crear / editar producto

Administrador

Figura 11

Flujo de navegación del administrador

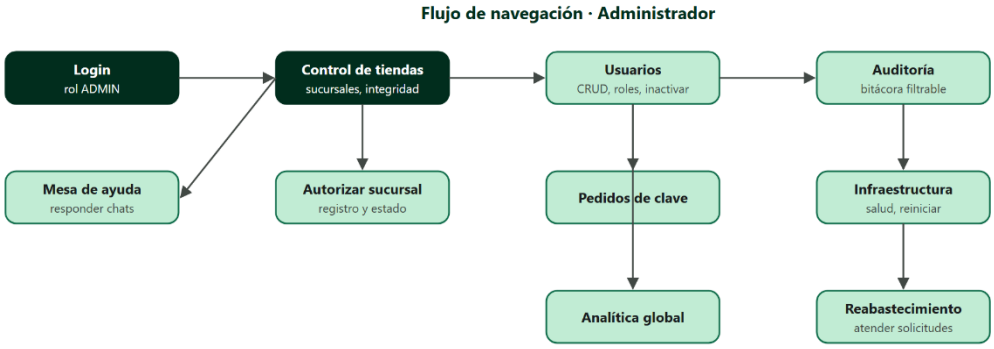
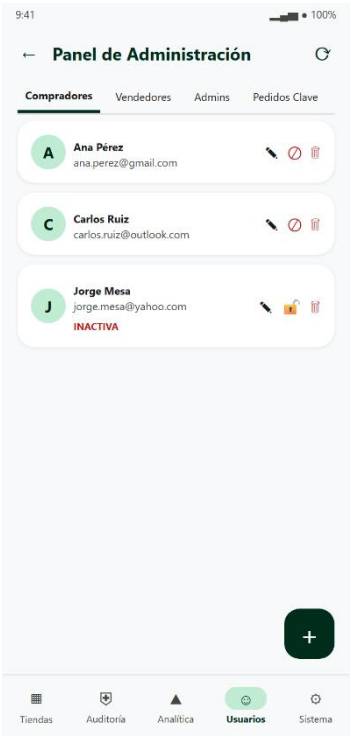


Figura 12

Pantallas del administrador: sucursales y usuarios



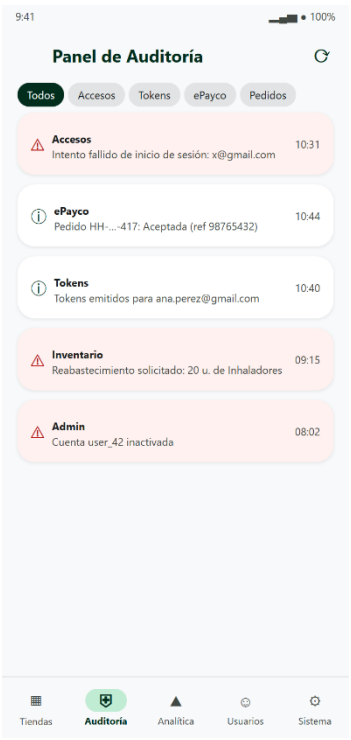
Control de tiendas



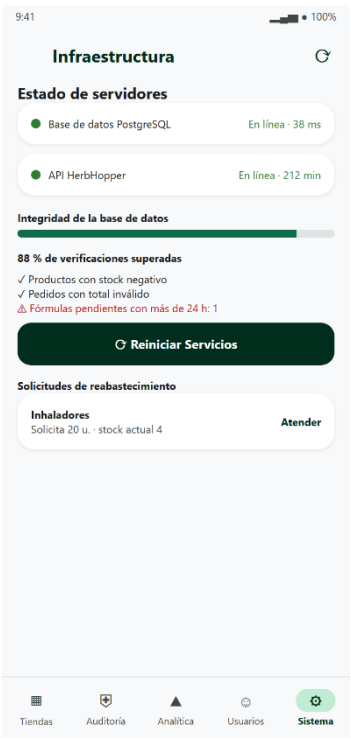
Administración de usuarios

Figura 13

Pantallas del administrador: auditoría e infraestructura



Auditoría



Infraestructura

Nota. Figuras 4 a 13: elaboración propia a partir de la interfaz implementada.

Referencias

Congreso de Colombia. (1999, 18 de agosto). *Ley 527 de 1999: Por medio de la cual se define y reglamenta el acceso y uso de los mensajes de datos, del comercio electrónico y de las firmas digitales*. Diario Oficial No. 43.673.

Congreso de Colombia. (2009, 5 de enero). *Ley 1273 de 2009: Por medio de la cual se modifica el Código Penal, se crea un nuevo bien jurídico tutelado denominado "de la protección de la información y de los datos"*.

Congreso de Colombia. (2011, 12 de octubre). *Ley 1480 de 2011: Por medio de la cual se expide el Estatuto del Consumidor y se dictan otras disposiciones*. Diario Oficial No. 48.220.

Congreso de Colombia. (2012, 17 de octubre). *Ley Estatutaria 1581 de 2012: Por la cual se dictan disposiciones generales para la protección de datos personales*. Diario Oficial No. 48.587.

Congreso de Colombia. (2016, 6 de julio). *Ley 1787 de 2016: Por medio de la cual se reglamenta el Acto Legislativo 02 de 2009*. Diario Oficial No. 49.926.

ePayco. (s. f.). *Documentación para desarrolladores: checkout y confirmación de transacciones*. https://docs.epayco.com

Google. (s. f.). *Documentación de Android para desarrolladores: BiometricPrompt, CameraX, Android Keystore y servicios de ubicación*. https://developer.android.com

PCI Security Standards Council. (2022). *Payment Card Industry Data Security Standard (versión 4.0)*. https://www.pcisecuritystandards.org

Presidencia de la República de Colombia. (2013, 27 de junio). *Decreto 1377 de 2013: Por el cual se reglamenta parcialmente la Ley 1581 de 2012*.

Presidencia de la República de Colombia. (2016, 11 de abril). *Decreto 587 de 2016: Por el cual se reglamenta el artículo 51 de la Ley 1480 de 2011*.

Presidencia de la República de Colombia. (2021, 23 de julio). *Decreto 811 de 2021: Por el cual se sustituye el Título 11 de la Parte 2 del Libro 2 del Decreto 780 de 2016, en relación con el acceso seguro e informado al uso del cannabis y de la planta de cannabis*.